

Founder-One-Pager: Aktueller Produktstand

Triagent: Evidence-first Phishing-Triage für regulierte Organisationen

Alexander Hülsmann – Masterstudent Informatik, Universität Münster

Kurzfassung

Triagent ist inzwischen kein reines Validierungskonzept mehr, sondern ein **lauffähiger On-Prem-Phishing-Triage-Demo-Stack**. Die Kernidee bleibt: Analysten sollen Phishing-Meldungen **nicht über verstreute Einzelschritte und Einzeltools** prüfen, sondern in einer Oberfläche technische Evidenz, Entscheidung und Dokumentation zusammenführen. Das Produkt ist heute **evidence-first, analyst-in-the-loop und kampagnenfähig**; es ist **noch nicht enterprise-fertig**, aber die Kern-Workflows sind als funktionierender Prototyp vorhanden.

Was heute konkret gebaut ist

- **Analyst Workspace:** Web-App mit Uploads, In-Tray, Dashboard, Admin-Bereich und vollständiger Report-Ansicht.
- **E-Mail-Intake:** Upload und Parsing von .eml und .msg, plus Outlook-Add-in für Meldungen aus dem Client.
- **Technische Analyse:** Header-/Auth-Auswertung (SPF, DKIM, DMARC), URL-Extraktion mit Redirect-Auflösung, Attachment-Metadaten, Transmission-Hop-Ansicht, Raw Source/X-Headers.
- **Analystische Hilfen:** Same-org Domain-Lookalike-Detection, ATT&CK-Mapping, IOC-Export, Risiko-/Verdachtskontext und Flagging einzelner Artefakte.
- **Evidenz & Nachvollziehbarkeit:** Export als JSON-Bundle, Markdown und PDF; zusätzlich IOC-Export als JSON/CSV; Original-Mail und Anhänge bleiben als Artefakte erhalten und downloadbar.
- **Betrieb & Governance:** RBAC, API Keys, Audit Log, Docker-Compose-Deployment sowie synthetischer Testkorpus für reproduzierbare Demos und Regressionstests.

Für wen

- **Nutzer:** SOC-Analysten / Phishing-Triage-Teams
- **Champion:** Analyst oder Teamlead mit hohem Pain bei Mail-Wellen und Audit-/Doku-Aufwand
- **Käufer:** SOC-Leitung / CISO in Umfeldern mit Datenhoheit, Compliance- und On-Prem-Anforderungen

Welches Problem Triagent adressiert

- Triage ist oft **tool-fragmentiert**: Header/Auth prüfen, URLs öffnen, Anhänge sichern, Doku schreiben, IOCs weiterreichen.
- In regulierten Umfeldern sind **externe Uploads oder SaaS-Workflows** oft politisch oder technisch schwierig.
- Viel Zeit geht nicht nur in die Entscheidung, sondern in **Begründung, Export und Auditierbarkeit**.
- Bei Phishing-Wellen entsteht zusätzlich **redundante Mehrfachprüfung ähnlicher Meldungen**.

Warum ich glaube, dass der Ansatz interessant ist

- **Kein generischer “AI SOC Copilot”:** enger, klarer Workflow mit überprüfbarer Evidenz.
- **On-Prem + nachvollziehbar:** Daten bleiben lokal, Original-Mail bleibt erhalten, Entscheidungen sind exportierbar.
- **Nicht nur Verdict, sondern Investigation Output:** Analysten bekommen Artefakte, IOC-Export, ATT&CK-Kontext und Bericht in einem Lauf.
- **Campaign Layer ist angelegt:** Kampagnen-Clustering, Zuordnung und Maintenance existieren im Backend/Data Model bereits; die eigentliche Produktvalidierung dafür ist der nächste große Schritt.

Was noch offen ist

- Heute ist es ein **starker Demo-/Pilot-Prototyp**, aber noch kein produktionsreifes Enterprise-Produkt.
- Es fehlen noch Dinge wie **SSO/IdP-Integration, tiefe Ticketing-/SIEM-Integrationen, härtere Packaging-/Ops-Story und echte Pilot-Feedbackschleifen**.
- Die größte offene Produktfrage ist: **Ist die erste Keilfunktion das einzelne Evidence-first-Report-Handling oder das kampagnenweise Arbeiten?**

Wobei ein Co-Founder besonders helfen könnte

- Produkt- und GTM-Schärfung: **welcher Entry Point zuerst wirklich zieht**
- Design-Partner- und Pilotzugang in Security-/SOC-Umfeldern
- Ergänzende Stärke in **Security-Produktisierung, Enterprise-Engineering oder kommerziellem Aufbau**